

ENCUESTA INTEGRAL DE EVALUACIÓN DE CIBERSEGURIDAD ORGANIZACIONAL

Modelo Detallado con Módulos y Escalas de Madurez

Versión: 1.0

Fecha: Enero 2026

Ámbito: Evaluación de madurez ciberseguridad, vulnerabilidades, pentesting, SIEM, capacitación

Metodología Base: BSIMM15, NIST CSF 2.0, IMC-INCIBE, GQM, FAIR

PRÓLOGO NARRATIVO: EL ARTE DE LA INQUISICIÓN CONSTRUCTIVA

Estimado Responsable de Seguridad de la Información,

Esta encuesta no es un cuestionario punitivo disfrazado de "evaluación". No viene con juez preestablecido ni sentencia a priori. Es, más bien, un acto de **introspección sistémica**: una invitación amable pero rigurosa a mirar dentro del espejo de la ciberseguridad de su organización, sin desviar la vista cuando la imagen resulta incómoda.

Porque—y aquí reside la ironía de nuestro tiempo—las organizaciones que más creen estar protegidas son a menudo las que menos lo están. No por maldad, sino por un problema arquitectónico de la modernidad: sabemos que hay puertas, pero no sabemos cuántas ventanas dejamos abiertas. Conocemos nuestros firewalls, pero ignoramos la formación de nuestro equipo. Hemos invertido en herramientas SIEM sofisticadas, pero no validamos si alguien realmente mira los logs cuando suenan las alarmas.

Esta encuesta es, en esencia, una cartografía de esa brecha.

Está diseñada bajo principios de **medición constructiva**: cada respuesta no es un fracaso, sino un dato. Cada "no sabemos" es una oportunidad, no una condena. Cada vacío identificado es un mapa para la mejora, no una sentencia de incompetencia.

Nos inscribimos en la tradición del **Goal-Question-Metric (GQM)** de la ingeniería de software: partimos de objetivos claros (seguridad operativa, cumplimiento normativo, resiliencia), generamos preguntas que desglosan esos objetivos, y recabamos métricas que las responden de forma cuantificable. Así, transformamos la vaguedad de "¿somos seguros?" en preguntas concretas: "¿testamos activamente nuestro código antes de producción?", "¿cuántos de nuestros empleados aprobaron el último test de phishing?", "¿cuál es nuestro MTTR medio en vulnerabilidades críticas?".

Este enfoque tiene el nivel de detalle de un **BSIMM15** (128 actividades observadas en empresas líderes), pero con la claridad operativa de un **IMC-INCIBE** (métricas territorial-españolas, pragmáticas). Incorpora **FAIR** para cuantificación probabilística de riesgo. Respeta **NIS2** (notificación incidentes, alineación vendor). Y abraza el rigor de **NIST CSF 2.0** con su nueva función Govern, sin perder de vista que la gobernanza sin capacitación es solo teatro.

Tono de la encuesta: Irónico, literario, propositivo.

- Irónico: Porque la realidad ciberseguridad está llena de paradojas hilantes. Invertimos millones en cortafuegos mientras dejamos contraseñas en post-its. Certificamos ISO 27001 pero probamos el plan de recuperación una vez cada cinco años. Publicamos políticas que nadie lee. Esta ironía no es sarcasmo destructivo, sino brújula para la verdad.
- Literario: Porque números sin narrativa son solo ruido. Cada escala de madurez es un acto en una obra: desde la Ignorancia Inaugural hasta la Optimización Perpetua. Cada módulo es un mundo; cada pregunta, una puerta a otro.
- Propositivo: Porque después de cada hallazgo viene una acción. No es diagnóstico sin prognosis. Cada respuesta alimenta un roadmap de mejora que trasciende la mera auditoría.

Irónico: Porque la realidad ciberseguridad está llena de paradojas hilantes. Invertimos millones en cortafuegos mientras dejamos contraseñas en post-its. Certificamos ISO 27001 pero probamos el plan de recuperación una vez cada cinco años. Publicamos políticas que nadie lee. Esta ironía no es sarcasmo destructivo, sino brújula para la verdad.

Literario: Porque números sin narrativa son solo ruido. Cada escala de madurez es un acto en una obra: desde la Ignorancia Inaugural hasta la Optimización Perpetua. Cada módulo es un mundo; cada pregunta, una puerta a otro.

Propositivo: Porque después de cada hallazgo viene una acción. No es diagnóstico sin prognosis. Cada respuesta alimenta un roadmap de mejora que trasciende la mera auditoría.

I. ESTRUCTURA GENERAL DE LA ENCUESTA

1.1 Módulos Temáticos (6)

Módulo	Descripción	# Preguntas	Escala
A. Governance & Strategy	Política, alineación ejecutiva, marcos de decisión	12	1-5 (Madurez)
B. Risk Management & Vulnerability Mgmt	Análisis riesgos, CVSS/EPSS, priorización	14	1-5 (Madurez)
C. Penetration Testing & Control Effectiveness	Pentesting, remediación, validación	10	1-5 (Madurez) + Métricas
D. SIEM & Logging	Agregación eventos, detección, incident response	13	1-5 (Madurez)
E. Employee Training & Awareness	Concienciación, phishing, formación especializada	11	1-5 (Madurez) + %
F. Compliance & NIS2 Readiness	NIS2, GDPR, ENS, auditoría, planes continuidad	10	1-5 (Madurez) + Booleano

Total: 70 preguntas + métricas auxiliares

1.2 Escala de Madurez Aplicada (Modelo IMC-INCIBE adaptado)

Nivel	Denominación	Descripción	Evidencia
L0	Inexistente	No existe; no se ha iniciado.	Ninguna.
L1	Iniciado/Incompleto	Esfuerzos ad-hoc, documentación parcial.	Evidencia anecdótica.
L2	Establecido, No Auditado	Proceso documentado, NO se valida regularmente.	Políticas escritas, pruebas <1x/año.
L3	Documentado y Operativo	Proceso formalizado, auditoría anual.	Auditoría interna, SLAs documentados.
L4	Gestionado y Verificado	Métricas continuas, optimización activa.	KPIs actualizados trimestral.
L5	Optimizado/Mejora Continua	Automatización, benchmarking externo, innovación.	Mejora iterativa, data-driven.

Nota: L5 es raro en la práctica (1% empresas España 2020); L3 es target NIS2 2026.

1.3 Tipos de Respuesta

1. Escala Likert (1-5): Madurez nivel (L0-L5 mapeado a 1-5)
2. Booleano (Sí/No): Cumplimiento básico (p.ej., ¿existe plan continuidad?).
3. Métrica Cuantitativa: Porcentaje (% empleados capacitados), días (MTTR), número (# vulnerabilidades críticas).
4. Opción Múltiple con Subtexto: Respuesta con matices contextuales.
5. Narrativa Breve (Evidencia): Ejemplos concretos que justifican madurez declarada.

II. MÓDULO A: GOVERNANCE & STRATEGY (12 PREGUNTAS)

Objetivo de Módulo (Goal - GQM)

Determinar si la ciberseguridad está gobernada por dirección ejecutiva, si hay alineación con negocio, y si existe framework de decisión basado en riesgo.

A.1 Existencia de Política Ciberseguridad Formal

Pregunta: ¿Existe una política de ciberseguridad aprobada formalmente por la Dirección?

Opciones (Escala 1-5):

1. **No existe** – Ni siquiera hemos pensado en formalizarlo (L0).
2. **Borrador circundante** – Existe algo en un compartida de drive, pero nadie recuerda cuándo se escribió (L1).
3. **Política documentada, pendiente aprobación** – Está escrita, pero sigue pasándose por manos de abogados (L2).
4. **Aprobada, comunicada al 50% de la org** – Existe, oficial, pero la mayoría de empleados desconoce su existencia (L3).
5. **Aprobada, comunicada, con acuerdos de cumplimiento firmados** – Política viva, revisada anualmente, con training obligatorio (L4-L5).

Métrica Auxiliar: ¿Año de última revisión? _

Métrica Auxiliar: % Empleados que pueden citar al menos 2 controles de la política: %

A.2 Roles y Responsabilidades Ciberseguridad

Pregunta: ¿Están claramente definidos los roles y responsabilidades en seguridad (CISO, Security Board, Data Owner, Data Protection Officer)?

Opciones:

1. **Nadie sabe quién es responsable de qué** – Es una nebulosa de "alguien debería..." (L0).
2. **Hay una persona (el CISO) que lo hace todo** – Heroísmo individual, nada escalable (L1).
3. **Roles documentados, pero con ambigüedades en límites** – Existen, pero a veces se solapan (L2).
4. **Roles formales, matriz RACI documentada, revisada anualmente** – Claro quién lidera, quién aprueba, quién ejecuta (L3).
5. **Roles integrados en OKRs ejecutivas, con bonificaciones/KPIs ligados** – La seguridad es incentivo empresarial, no castigo (L4-L5).

Métrica Auxiliar: ¿Existe una Matrix RACI publicada? (Sí/No)

Métrica Auxiliar: Número de jornadas de capacitación en roles/responsabilidades/año: ____

A.3 Gobernanza: Existe Comité de Seguridad

Pregunta: ¿Existe un Comité de Dirección/CISO que revise regularmente el estado de ciberseguridad?

Opciones:

1. **No existe comité** – La seguridad se decide cuando hay crisis (L0).
2. **Reuniones ad-hoc cuando "sale algo"** – Respuesta reactiva a brechas mediáticas (L1).
3. **Reuniones trimestrales, actas desorganizadas** – Existe, pero sin follow-up (L2).
4. **Reuniones mensuales/trimestrales formales, con actas y follow-up documentado** – Cadencia clara, ownership de acciones (L3).
5. **Reuniones mensuales con dashboard ejecutivo, scorecards, trends, benchmarking vs industry** – Datos vivos, decisiones data-driven (L4-L5).

Métrica Auxiliar: ¿Cuántas reuniones de comité seguridad se han celebrado en los últimos 12 meses? _

Métrica Auxiliar: % de acciones del comité que se cerraron vs abiertas: %

A.4 Alineación Ciberseguridad-Negocio

Pregunta: ¿La estrategia de ciberseguridad está alineada con objetivos empresariales (OKRs, Plan Estratégico)?

Opciones:

1. **Ninguna conexión visible** – Seguridad es visto como overhead IT, no negocio (L0).
2. **Vagas conexiones** – "La seguridad es importante porque el CEO lo dice" (L1).
3. **Documentado en plan anual, pero sin métricas de impacto** – Existe documento, pero suena genérico (L2).
4. **Integrado en objetivos estratégicos con métricas (ej: "reducir MTTDetect a <4hrs", "zero critical vulnerabilities prod")** – Objetivos SMART, revisados (L3).
5. **OKRs de seguridad impactan bonus ejecutivo; automatización de controles vinculada a negocio outcomes** – Incentivos alineados (L4-L5).

Métrica Auxiliar: Escriba 2 OKRs de seguridad de su organización para 2026: __

A.5 Tolerancia al Riesgo Formalizada (Risk Appetite)

Pregunta: ¿Ha definido formalmente el "riesgo residual aceptable" (risk appetite) de la organización?

Opciones:

1. **¿Tolerancia al riesgo? Eso suena académico.** – No existe concepto (L0).
2. **Interpretación vaga de lo que "debería ser aceptable"** – Conversaciones de café, no documentado (L1).
3. **Documento de risk appetite, pero no se usa en decisiones** – Existe, pero es decorativo (L2).
4. **Risk appetite documentado, usado en decisiones de priorización de controles** – Influye en qué se remedia primero (L3).

5. Risk appetite por categoría (datos, infraestructura, terceros), con umbrales numéricos de riesgo residual – Sofisticado, FAIR-aligned (L4-L5).

Métrica Auxiliar: Riesgo residual máximo aceptable en € o %: _

Métrica Auxiliar: % de decisiones de mitigación basadas explícitamente en risk appetite: %

A.6 Presupuesto Ciberseguridad Formalmente Asignado

Pregunta: ¿Existe un presupuesto de ciberseguridad formalizado, aprobado anualmente por Dirección?

Opciones:

1. **No hay presupuesto; se paga "de donde surja"** – Improvisación constante (L0).
2. **Presupuesto adhoc año a año, sin predictibilidad** – Depende de caprichos ejecutivos (L1).
3. **Presupuesto anual aprobado, pero sin desglose de ROI esperado** – Existe, pero no se justifica (L2).
4. **Presupuesto aprobado con desglose: herramientas, personal, training, terceros** – Estructurado (L3).
5. **Presupuesto multianual, con ROI tracking, benchmarking vs industry, reajustes según riesgo** – Strategic (L4-L5).

Métrica Auxiliar: Presupuesto anual ciberseguridad (€): _

Métrica Auxiliar: % de presupuesto vs ingresos anuales: %

Métrica Auxiliar: % del presupuesto usado/gastado: __%

A.7 Tercerización de Servicios Seguridad (Vendor Management)

Pregunta: ¿Existen criterios formales para seleccionar, auditar y gestionar proveedores de ciberseguridad?

Opciones:

1. **Usamos lo que nos recomienda el vendedor de software** – Sin evaluation (L0).
2. **Llamamos a varios consultores, elegimos por precio** – Criterio costo, sin due diligence (L1).
3. **Evaluamos consultores, pero sin verificación de cumplimiento post-contratación** – Onboarding, sin follow-up (L2).
4. **Política de vendor seguridad documentada: criteria, SLAs, auditoría anual, contrato compliance** – Formal (L3).
5. **Gestión dinámica de vendors: scorecards, benchmarking, revisión trimestral, integration con SIEM, automated compliance** – Advanced (L4-L5).

Métrica Auxiliar: Número de proveedores ciberseguridad activos: _

Métrica Auxiliar: % que tienen certificación ISO 27001 o equivalente: %

A.8 Gestión de Cambios en Seguridad

Pregunta: ¿Existe proceso formal de revisión de seguridad antes de cambios en infraestructura (CAB - Change Advisory Board)?

Opciones:

1. **Cambios sin revisar de seguridad, descubrimiento post-implementación** – Caos (L0).
2. **A veces se avisa al equipo de seguridad, pero no siempre** – Inconsistente (L1).
3. **Existe CAB con seguridad, pero criterios vagos de aprobación** – Estructura débil (L2).
4. **CAB formalizado, checklist de seguridad obligatorio, reuniones previas documentadas** – Riguroso (L3).
5. **CAB automático con herramientas, risk scoring, rollback automático si incumple, trazabilidad** – Automated (L4-L5).

Métrica Auxiliar: % de cambios con revisión seguridad previa: %

Métrica Auxiliar: MTTR promedio de rollback por cambio problemático: _ horas

A.9 Auditoría Interna de Seguridad

Pregunta: ¿Se realiza auditoría interna de seguridad regularmente (self-assessment)?

Opciones:

1. **Nunca nos auditamos a nosotros mismos** – "Confiamos en nosotros" (L0).
2. **Auditoría ocasional cuando hay crisis o exigencia externa** – Reactiva (L1).
3. **Auditoría anual de algunos controles clave** – Parcial (L2).
4. **Auditoría anual formal de todos controles, documentada, con hallazgos y plan de acción** – Estructurado (L3).
5. **Auditoría continua automatizada + auditoría manual trimestral, con métricas de cumplimiento** – Proactive (L4-L5).

Métrica Auxiliar: Hallazgos críticos pendientes de remediación: _

Métrica Auxiliar: MTTR promedio auditoría hallazgo – cierre: _ días

A.10 Comunicación de Incidentes a Stakeholders

Pregunta: ¿Existe plan formal de comunicación interna/externa en caso de incidente (notificación NIS2, reguladores, clientes)?

Opciones:

1. **Comunicamos cuando nos acuerdan** – "Decir es fácil, se dice como nos parece" (L0).
2. **Existe borrador de plan, pero no se ha probado** – Teórico (L1).
3. **Plan documentado, pero sin simulacros** – Estático (L2).
4. **Plan formalizado, revisado anualmente, con simulacro 1x/año** – Operativo (L3).
5. **Plan integrado en playbooks, pruebas 2x/año, scripts automáticos de notificación, tracking de respuesta regulador** – Sophisticated (L4-L5).

Métrica Auxiliar: ¿Año de último simulacro incidente? _

Métrica Auxiliar: Tiempo máximo para notificación regulador NIS2: _ horas (legal: 24h)

A.11 Inversión en Capacitación del Equipo Seguridad

Pregunta: ¿Se invierte en formación continua del equipo de ciberseguridad (certificaciones, conferencias, cursos)?

Opciones:

1. **Presupuesto zero, aprenden sobre la marcha** – Trial and error (L0).
2. **Algo de presupuesto, pero muy limitado (<€2k/año per capita)** – Superficial (L1).
3. **Presupuesto anual por persona (€2-5k), conferencias ocasionales** – Presente (L2).
4. **Presupuesto dedicado (€5-10k/pers), 1-2 certificaciones/año requeridas, conferencias** – Robusto (L3).
5. **Presupuesto generoso (>€10k/pers), path de especialización claro, sandbox labs internos, investigación** – Investment (L4-L5).

Métrica Auxiliar: Presupuesto formación equipo seguridad/año: €_

Métrica Auxiliar: Número de certificaciones del equipo (CISSP, CEH, OSCP, etc.): _

Métrica Auxiliar: % equipo que asistió a conferencia/evento externo en 12 meses: __%

A.12 Cultura de Seguridad en la Organización

Pregunta: ¿Se ha instaurado una "cultura de seguridad" o sigue siendo percibida como "algo que hace IT"?

Opciones:

1. **Seguridad = obstáculo burocrático que ralentiza desarrollo** – Cultura adversaria (L0).
2. **Algunos líderes entienden importancia, pero no es transversal** – Islas de conciencia (L1).
3. **Se reconoce importancia, pero no hay alineación en incentivos** – Reconocimiento débil (L2).
4. **Seguridad es parte del ADN: premios a vulnerabilidades descubiertas, incidentes sin culpa, training obligatorio** – Embedded (L3).
5. **Bug bounty program activo, seguridad en hiring criteria, rotación roles seguridad en negocio, investigación interna** – Mature (L4-L5).

Métrica Auxiliar: ¿Existe bug bounty program? (Sí/No)

Métrica Auxiliar: % de violaciones de seguridad reportadas vs detectadas (engagement metric): %

Métrica Auxiliar: Puntuación eNPS (Employee Net Promoter Score) sobre seguridad: _

III. MÓDULO B: RISK MANAGEMENT & VULNERABILITY MANAGEMENT (14 PREGUNTAS)

Objetivo de Módulo (Goal - GQM)

Determinar madurez en identificación, cuantificación, priorización y remediación de vulnerabilidades y riesgos.

B.1 Análisis de Riesgos Formal (Risk Assessment)

Pregunta: ¿Se realiza análisis formal de riesgos de ciberseguridad al menos anualmente?

Opciones:

1. **Nunca, asumimos que "algo podría pasar"** – Adivinanza (L0).
2. **Análisis ad-hoc cuando surge crisis** – Reactivo (L1).
3. **Análisis anual, pero con metodología vaga (cualitativa, sin números)** – Superficial (L2).
4. **Análisis anual formal: identificación activos, amenazas, vulnerabilidades, matriz riesgo** – Estructura (L3).
5. **Análisis probabilístico (FAIR-based) trimestral: Loss Event Frequency, Loss Magnitude, cuantificación en €** – Sophisticated (L4-L5).

Métrica Auxiliar: ¿Metodología de risk assessment usada? (NIST, MAGERIT, FAIR, otra): _

Métrica Auxiliar: Número de riesgos críticos identificados en último análisis: _

B.2 Inventario de Activos (Asset Register)

Pregunta: ¿Existe un inventario centralizado y actualizado de activos críticos (servidores, aplicaciones, datos)?

Opciones:

1. **Cada departamento mantiene su lista en una hoja de cálculo** – Fragmentado (L0).
2. **Hay un registro, pero se actualiza irregularmente (cuando alguien se acuerda)** – Outdated (L1).
3. **Registro centralizado, actualizado anualmente en revisión auditoria** – Periodic (L2).
4. **Registro dinámico, actualizado cuando hay cambios, integrado en CMDB** – Real-time (L3).
5. **Inventario automatizado (CMDB + scanning), con etiquetas de criticidad, custodia, clasificación datos, linkage incidentes** – Autonomous (L4-L5).

Métrica Auxiliar: Número de activos críticos identificados: _

Métrica Auxiliar: Porcentaje de activos en inventario vs "descubiertos" recientemente: %

B.3 Clasificación de Datos (Data Classification)

Pregunta: ¿Existen criterios formales de clasificación de datos (confidencial, interno, público)?

Opciones:

1. **"Nuestros datos son secretos"** – Sin granularidad (L0).
2. **Existe algo escrito, pero no se aplica consistentemente** – Inconsistente (L1).
3. **Clasificación documentada, aplicada en algunos sistemas** – Parcial (L2).
4. **Clasificación formal, aplicada a 80%+ datos, con pautas de protección asociadas** – Operativo (L3).
5. **Clasificación automática (DLP tools), con etiquetas dinámicas, auditoría de cumplimiento, re-clasificación periódica** – Automated (L4-L5).

Métrica Auxiliar: % de datos clasificados: %

Métrica Auxiliar: Número de categorías de clasificación usadas: _

B.4 Vulnerability Scanning (Escaneo Vulnerabilidades)

Pregunta: ¿Se realiza escaneo automático de vulnerabilidades regularmente?

Opciones:

1. **Nunca hemos escaneado; confiamos en nuestras compilaciones** – Ceguera (L0).
2. **Escaneo ocasional cuando lo pide auditoría** – Compliance theatre (L1).
3. **Escaneo mensual o trimestral de aplicaciones principales** – Básico (L2).
4. **Escaneo semanal o continuo (SAST/DAST) de toda stack, automatizado en pipeline** – Continuous (L3).
5. **Scanning multi-capa automatizado: SAST + DAST + SCA + infrastructure + API + mobile, con correlación de vulnerabilidades** – Comprehensive (L4-L5).

Métrica Auxiliar: Herramientas de scanning usadas (ej: Sonarqube, Veracode, Rapid7): _

Métrica Auxiliar: Frecuencia de scanning: (Diaria/Semanal/Mensual/Trimestral): _

Métrica Auxiliar: % de vulnerabilidades remediadas antes de despliegue a producción: __%

B.5 Evaluación de Vulnerabilidades (CVSS & EPSS)

Pregunta: ¿Se utilizan estándares de severidad de vulnerabilidades (CVSS v3.1, EPSS)?

Opciones:

1. **"Crítico", "Alto", "Bajo"... sin estándar** – Subjetivo (L0).
2. **Se menciona CVSS, pero se usa inconsistentemente** – Superficial (L1).
3. **Todas vulnerabilidades tienen CVSS score, pero no se usa EPSS** – Básico (L2).
4. **CVSS + EPSS, correlacionados en dashboard, usado para priorización** – Operativo (L3).
5. **Scoring sofisticado: CVSS + EPSS + environmental metrics + threat intelligence + exploit availability + CISA KEV** – Advanced (L4-L5).

Métrica Auxiliar: ¿Se utiliza EPSS en decisiones de priorización? (Sí/No)

Métrica Auxiliar: % de vulnerabilidades con score CVSS vs sin score: __%

B.6 Priorización de Remediación (Vulnerability Triage)

Pregunta: ¿Existe proceso formal de decisión sobre qué vulnerabilidades remediar primero?

Opciones:

1. **Lo que grita más alto, primero** – Caos (L0).
2. **Vendedor presiona, arreglamos** – Reactivo (L1).
3. **Se intenta priorizarlas, pero sin criterios claros** – Adhoc (L2).
4. **Matriz de priorización: CVSS + EPSS + criticidad activo + context** – Formalizado (L3).
5. **Priorización automática: algoritmo que pesa CVSS + EPSS + TI + explotabilidad + impacto negocio + SLAs, con triage colaborativo** – Sophisticated (L4-L5).

Métrica Auxiliar: SLA promedio para remediación crítica: _ días

Métrica Auxiliar: % de vulnerabilidades críticas remediadas en 30 días: %

B.7 Gestión de Vulnerabilidades de Terceros (Supply Chain)

Pregunta: ¿Se monitorean vulnerabilidades en librerías, frameworks y dependencias de software de terceros?

Opciones:

1. **Esperamos que los vendors nos lo comuniquen** – Pasivo (L0).
2. **Revisamos ocasionalmente, pero sin sistemática** – Adhoc (L1).
3. **Existe herramienta SCA (Software Composition Analysis), pero se ejecuta < 1x/mes** – Básico (L2).
4. **SCA continuo integrado en pipeline, con alertas automáticas, SBOM generado** – Operativo (L3).
5. **SCA + dependency tracking + automated patching para librerías, policy compliance, vendor communication formalized** – Advanced (L4-L5).

Métrica Auxiliar: ¿Se genera SBOM (Software Bill of Materials) de aplicaciones? (Sí/No)

Métrica Auxiliar: Promedio de dependencias con vulnerabilidades conocidas por aplicación: ____

B.8 Parches y Actualizaciones (Patch Management)

Pregunta: ¿Existe proceso formalizado de aplicación de parches de seguridad?

Opciones:

1. **Actualizamos cuando el sistema deja de funcionar** – Crisis-driven (L0).
2. **Parcheamos irregularmente, sin schedule fijo** – Unpredictable (L1).
3. **Calendario de parches mensual/trimestral, pero con demoras** – Basic (L2).
4. **Schedule formalizado: críticos <7d, altos <30d, documentado en CAB** – Operativo (L3).
5. **Patch management automático con staging, validation, rollback, excepciones minimizadas** – Autonomous (L4-L5).

Métrica Auxiliar: MTTR promedio para parches críticos: _ días

Métrica Auxiliar: % de sistemas en patch level "actual" vs desactualizado: %

B.9 Configuración Segura (Hardening)

Pregunta: ¿Se aplican configuraciones de seguridad baseline (CIS Benchmarks, NIST, etc.)?

Opciones:

1. **Configuramos por defecto** – Ad-hoc (L0).
2. **Existe documento de hardening, pero no se valida cumplimiento** – Theoretical (L1).
3. **Baseline documentado, aplicado a nuevos sistemas** – Partial (L2).
4. **Baseline formalizado y auditado anualmente, con documentación de excepciones justificadas** – Operativo (L3).
5. **Hardening automatizado (IaC), validado en pipeline, compliance scanning continuo** – Automated (L4-L5).

Métrica Auxiliar: % de sistemas cumpliendo con CIS Benchmark: %

Métrica Auxiliar: Excepciones de hardening formalmente aprobadas: _

B.10 Gestión de Contraseñas y Acceso

Pregunta: ¿Existe policy formalizada de contraseñas y gestión de acceso privilegiado (PAM)?

Opciones:

1. **"Usa contraseña fuerte" y ... eso es todo** – Vago (L0).
2. **Policy escrita: longitud mínima, cambio cada X meses** – Básica (L1).
3. **Policy + herramienta de gestión contraseñas, pero sin MFA general** – Operativo parcial (L2).
4. **Policy formalizada, MFA obligatoria, gestión contraseñas centralizada, PAM para admin** – Robusto (L3).
5. **PAM sofisticado: zero-trust, passwordless (FIDO2), encryption, audit trail, anomaly detection** – Advanced (L4-L5).

Métrica Auxiliar: % de usuarios con MFA activo: %

Métrica Auxiliar: ¿Se tiene herramienta PAM? (Sí/No). Si sí: nombre: _

B.11 Gestión de Secretos (Credentials)

Pregunta: ¿Se gestionan activamente los secretos (API keys, tokens, certificados) en aplicaciones?

Opciones:

1. **Secrets hardcoded en código fuente** – Pesadilla (L0).
2. **Algunos secretos en config, pero sin cifrar** – Inseguro (L1).
3. **Secretos en archivos cifrados, pero acceso manual** – Ad-hoc (L2).
4. **Gestión de secretos centralizada (Vault, HashiCorp), rotación automática** – Operativo (L3).
5. **Secrets management integrado en pipeline, con encryption at-rest & transit, audit, automatic rotation, anomaly detection** – Advanced (L4-L5).

Métrica Auxiliar: ¿Se utiliza herramienta de secrets management (Vault, AWS Secrets Manager, etc.)? (Sí/No)

Métrica Auxiliar: % de aplicaciones con secretos gestionados centralizadamente: ___%

B.12 Monitoreo de Riesgos en Tiempo Real

Pregunta: ¿Existe capacidad de monitoreo continuo de riesgos emergentes (threat intelligence, zero-days)?

Opciones:

1. **No monitoreamos; confiamos en que "alguien" lo haga** – Esperanza (L0).
2. **Subscripción a newsletter de seguridad, lectura ocasional** – Passive (L1).
3. **Acceso a feed de TI (NVD, CISA KEV), revisión diaria manual** – Manual (L2).
4. **Integración de threat feeds en SIEM, alertas automáticas para CVEs críticos aplicables** – Operativo (L3).
5. **Threat intelligence feed automation, correlation con activos propios, risk scoring dinámico, automated response workflows** – Sophisticated (L4-L5).

Métrica Auxiliar: Fuentes de threat intelligence suscritas: _

Métrica Auxiliar: Tiempo promedio entre publicación CVE crítico y awareness interna: _ horas

B.13 Métrica FAIR: Cuantificación de Riesgo en €

Pregunta: ¿Se cuantifica el riesgo en términos monetarios (Loss Event Frequency × Loss Magnitude)?

Opciones:

1. **Riesgo es un concepto cualitativo para nosotros** – Fuzzy (L0).
2. **Intentamos calcularlo, pero sin metodología clara** – Ad-hoc (L1).
3. **Algunos riesgos estimados en €, pero sin rigor FAIR** – Approximate (L2).
4. **Análisis FAIR parcial: LEF × LM estimado para riesgos top 5** – Basic FAIR (L3).
5. **Modelo FAIR completo con Monte Carlo simulation, escenarios, distribuciones probabilísticas** – Full FAIR (L4-L5).

Métrica Auxiliar: Riesgo residual total estimado en €: €_

Métrica Auxiliar: Riesgo máximo por categoría (datos, infraestructura, terceros): €_ cada

B.14 Revisión y Actualización del Análisis de Riesgo

Pregunta: ¿Con qué frecuencia se revisa y actualiza el análisis de riesgos?

Opciones:

1. **Nunca se revisa; es "set and forget"** – Estático (L0).
2. **Revisión cuando hay cambio importante (upgrade, nueva amenaza)** – Event-driven (L1).
3. **Revisión anual obligatoria, aunque sea pro-forma** – Periodic (L2).
4. **Revisión trimestral formal con actas, actualización de datos clave** – Structured (L3).
5. **Revisión continua con paneles vivos, datos en tiempo real, modelos de escenarios actualizables** – Continuous (L4-L5).

Métrica Auxiliar: ¿Año de última revisión formal del risk assessment? _

Métrica Auxiliar: Riesgos re-evaluados en últimos 12 meses: _/total

IV. MÓDULO C: PENETRATION TESTING & CONTROL EFFECTIVENESS (10 PREGUNTAS)

Objetivo de Módulo (Goal - GQM)

Determinar frecuencia, calidad y efectividad de pruebas de penetración y validación de controles.

C.1 Frecuencia de Penetration Testing

Pregunta: ¿Se realizan pruebas de penetración (pentesting) regularmente?

Opciones:

1. **Nunca hemos contratado un pentester** – Virgen (L0).
2. **Pentesting una vez hace 5+ años** – Outdated (L1).
3. **Pentesting anual, coverage incompleto** – Periodic (L2).
4. **Pentesting anual + assessment continuo de aplicaciones críticas** – Regular (L3).

5. Pentesting 2x/año + red teaming + continuous pentest platform + bug bounty program – Comprehensive (L4-L5).

Métrica Auxiliar: ¿Año del último pentesting? _

Métrica Auxiliar: Aplicaciones/sistemas pentested vs total aplicaciones: _/___

C.2 Cobertura de Pentesting

Pregunta: ¿Cubre el pentesting todas las superficies de ataque (web apps, APIs, infraestructura, wireless, física)?

Opciones:

1. **Pentesting limitado a "algo de web" – Superficial (L0).**
2. **Principalmente aplicaciones web; falta infraestructura, APIs – Partial (L1).**
3. **Cubre web + infraestructura; falta wireless, física, terceros – Good (L2).**
4. **Pentesting comprehensivo: web + APIs + infra + wireless + física + terceros, documentado en scope – Thorough (L3).**
5. **Pentesting + red team + supply chain testing + insider simulation + AI attack scenarios – Advanced (L4-L5).**

Métrica Auxiliar: Superficies de ataque testeadas (marcar): Web() APIs() Infra() Wireless() Física() Terceros()

C.3 Tipo de Pentesting: Manual vs Automatizado

Pregunta: ¿Es el pentesting principalmente manual o se basa en herramientas automatizadas?

Opciones:

1. **Automatizadas solo (escáneres, sin análisis profundo) – Shallow (L0-L1).**
2. **Mayormente automatizadas, poco análisis manual – Mostly automated (L1-L2).**
3. **Mezcla de automatizadas + análisis manual de hallazgos top – Balanced (L2-L3).**
4. **Mostly manual con validación automática, chained attacks, business logic flaws – Manual-driven (L3-L4).**
5. **Pentesting experto: manuales avanzados, exploit chaining, lateral movement, post-explotación – Expert (L4-L5).**

Métrica Auxiliar: % del pentesting que es manual vs automatizado: % / %

C.4 Validación de Resultados

Pregunta: ¿Se validan y verifican reproducibilidad de hallazgos del pentesting?

Opciones:

1. **Se reporta; asumimos que es correcto – No verification (L0).**
2. **Validation ocasional, principalmente del proveedor – Superficial (L1).**
3. **Equipo interno valida hallazgos críticos antes de priorizar remediación – Partial (L2).**
4. **Reproducibilidad verificada por equipo independiente interno, con POC documentado –**

Rigorous (L3).

5. Automated validation + manual verification + false positive rate tracked + vendor knowledge transfer – Sophisticated (L4-L5).

Métrica Auxiliar: % de hallazgos pentesting validados internamente: %

Métrica Auxiliar: % de false positives históricos en pentestings: %

C.5 Remediación de Hallazgos Pentesting

Pregunta: ¿Cuál es el promedio de tiempo para remediar vulnerabilidades críticas encontradas en pentesting?

Opciones:

1. **Reportadas hace 2+ años; aún no remediadas** – Negligence (L0).
2. **Remediación lenta; promedio 6+ meses** – Sluggish (L1).
3. **MTTR 90-180 días para críticas** – Moderate (L2).
4. **MTTR 30-90 días para críticas; SLA documentado** – Good (L3).
5. **MTTR <30 días para críticas; algunos remediados en 7 días** – Excellent (L4-L5).

Métrica Auxiliar: MTTR crítico (Mean Time To Remediate): _ días

Métrica Auxiliar: % de hallazgos críticos remediados en 30 días: %

Métrica Auxiliar: Hallazgos pendientes >90 días: ____

C.6 Revalidación Post-Remediación

Pregunta: ¿Se revalida que la remediación fue efectiva (retesting)?

Opciones:

1. **El vendor reportó "fixed"; confiamos** – No verification (L0).
2. **Occasionally se prueba si fue arreglado** – Ad-hoc (L1).
3. **Retesting para hallazgos críticos antes de cerrar, pero no formalizado** – Partial (L2).
4. **Retesting formalizado: 100% hallazgos críticos revalidados, documentado** – Operational (L3).
5. **Continuous validation: automated testing post-deployment, false negative tracking, root cause analysis** – Continuous (L4-L5).

Métrica Auxiliar: % de hallazgos críticos revalidados post-remediación: %

Métrica Auxiliar: % de re-aparición de hallazgos (regression rate): %

C.7 Métricas de Efectividad de Controles (Control Testing)

Pregunta: ¿Se realizan pruebas de efectividad (Test of Design & Test of Effectiveness) de controles?

Opciones:

1. **No; asumimos que controles funcionan** – No testing (L0).
2. **Pruebas ocasionales, principalmente reactivas tras incidente** – Event-driven (L1).
3. **Pruebas de diseño documentadas en auditoría anual, sin testing de efectividad operativa** – Design only (L2).

4. **Test of Design + Test of Effectiveness de controles clave, mínimo 1x/año** – Dual testing (L3).
5. **ToD + ToE continuo, sampling estratificado, anomaly detection, automated reporting** – Continuous (L4-L5).

Métrica Auxiliar: # de controles sujetos a ToE en 12 meses: _

Métrica Auxiliar: % de controles que pasaron ToE: %

C.8 Integración Pentesting en SDLC (Shift-Left)

Pregunta: ¿Se integra testing de seguridad en el proceso de desarrollo (antes de producción)?

Opciones:

1. **Seguridad se prueba en producción** – Post-deployment (L0).
2. **Testing de seguridad ocasional pre-deployment** – Adhoc (L1).
3. **SAST en pipeline, DAST pre-release, pero sin rigor** – Basic (L2).
4. **SAST + DAST + SCA automático en pipeline, gates de calidad definidos** – Integrated (L3).
5. **Shift-left avanzado: unit tests seguridad, architecture review, SBOM, deployment validation** – Shifted (L4-L5).

Métrica Auxiliar: ¿Se bloquea despliegue a prod si hay vulnerabilidades críticas SCA? (Sí/No)

Métrica Auxiliar: % de aplicaciones testeadas pre-deployment: __%

C.9 Reporte y Comunicación de Pentesting

Pregunta: ¿Qué tan clara y accionable es la comunicación de resultados pentesting?

Opciones:

1. **Reporte genérico, poco contexto, difícil de remediar** – Poor quality (L0-L1).
2. **Reporte con hallazgos, pero falta contexto técnico o business impact** – Adequate (L1-L2).
3. **Reporte claro con proof-of-concept, severidad, recomendaciones, pero sin priorización de negocio** – Good (L2-L3).
4. **Reporte comprehensivo: POC, CVSS, EPSS, business impact, remediation path, executive summary** – Excellent (L3-L4).
5. **Multi-tiered reporting: technical + executive + risk quantification (FAIR), interactive dashboard, vendor knowledge transfer** – Sophisticated (L4-L5).

Métrica Auxiliar: Tiempo entre pentesting y reporte recibido: _ días

Métrica Auxiliar: % de hallazgos que se comprenden y priorizan correctamente: %

C.10 Red Team Exercises

Pregunta: ¿Se realizan ejercicios de red team (simulación adversaria avanzada)?

Opciones:

1. **No hay red team** – Untested (L0).
2. **Red team externo 1x cada 3-5 años** – Rare (L1).
3. **Red team bianual, enfocado en infraestructura** – Periodic (L2).

4. Red team anual, incluyendo social engineering + infraestructura + respuesta incidente – Regular (L3).

5. Red team continuo: purple team exercises, threat scenario-driven, integration con incident response drills – Advanced (L4-L5).

Métrica Auxiliar: ¿Cuándo fue el último red team exercise? _

Métrica Auxiliar: Duración típica de red team exercise: _ días/semanas

V. MÓDULO D: SIEM & LOGGING (13 PREGUNTAS)

Objetivo de Módulo (Goal - GQM)

Determinar capacidad de centralización, correlación, detección y respuesta a eventos de seguridad.

D.1 Existencia de SIEM

Pregunta: ¿Utiliza una herramienta SIEM centralizada o solución de log management equivalente?

Opciones:

- 1. Cada sistema mantiene sus propios logs – Fragmented (L0).**
- 2. Hay un servidor central para logs, pero sin análisis – Basic log management (L1).**
- 3. SIEM/log management con análisis básico, pero sin correlación avanzada – Functional (L2).**
- 4. SIEM maduro con correlación, alertas automáticas, reporting compliance – Operational (L3).**
- 5. SIEM avanzado con UEBA, threat intelligence integration, automated response (SOAR) – Sophisticated (L4-L5).**

Métrica Auxiliar: Herramienta SIEM utilizada (ej: Splunk, ELK, ArcSight): _

Métrica Auxiliar: Años de operación SIEM: _

D.2 Fuentes de Logs Integradas

Pregunta: ¿Cuáles son las categorías de fuentes que envían logs al SIEM?

Opciones (Marcar todas las aplicables):

- Firewalls ()
- Servidores Windows/Linux ()
- Active Directory/IAM ()
- Aplicaciones (web, base datos) ()
- Endpoints (EDR) ()
- Cloud services (AWS, Azure, Microsoft 365) ()
- Dispositivos de red (switches, routers) ()
- Teléfonos IP / UC ()
- Sistemas críticos ICS/SCADA ()
- Terceros/partners ()

Métrica Auxiliar: Total de fuentes de logs integradas: _

Métrica Auxiliar: % de fuentes críticas con logs en SIEM: %

D.3 Cobertura de Eventos Logeados

Pregunta: ¿Qué categorías de eventos se registran y monitorean?

Opciones (Marcar todas):

- Acceso/autenticación (logon, failed login) ()
- Acceso a datos (file access, database query) ()
- Cambios privilegiados (admin actions, sudo) ()
- Cambios de configuración (firewall rules, policy changes) ()
- Malware/antivirus (detecciones, cuarentena) ()
- Network anomalies (unusual traffic, DDoS) ()
- Application errors (crashes, exceptions) ()
- User behavior (unusual patterns) ()
- Compliance events (access to PII, regulated data) ()
- Third-party integrations (vendor alerts) ()

Métrica Auxiliar: Número de eventos/segundo procesados por SIEM: **_ EPS**

Métrica Auxiliar: Capacidad de retención de logs (días): **_**

D.4 Normalización y Parsing de Logs

Pregunta: ¿Se normalizan los logs de múltiples fuentes a un formato común para análisis?

Opciones:

1. **Logs en formato nativo; no se normalizan** – Raw (L0).
2. **Normalización básica, pero con gaps** – Partial (L1).
3. **Normalización formalizada de logs principales, no 100%** – Mostly normalized (L2).
4. **Normalización de 80%+ logs, con excepciones documentadas** – Operational (L3).
5. **Normalización automatizada de nuevas fuentes, validación de integridad, schema evolution** – Automated (L4-L5).

Métrica Auxiliar: % de logs que se normalizan exitosamente: **%**

Métrica Auxiliar: % de parsing errors (logs no interpretados): **%**

D.5 Retención de Logs (Data Retention)

Pregunta: ¿Cuál es la política de retención de logs?

Opciones:

1. **Logs se borran rápido; "no hay almacenamiento"** – Days (L0).
2. **Retención de 30 días** – Minimal (L1).
3. **Retención de 90 días online, archivos offline** – Partial (L2).
4. **Retención de 1 año + archivos de auditoría 7+ años (compliance)** – Compliant (L3).
5. **Retención multitier: hot (90d online), warm (1 year), cold (7 años archived), con tiered access** – Sophisticated (L4-L5).

Métrica Auxiliar: Retención online (días): _

Métrica Auxiliar: Retención total (años): _

D.6 Alertas y Reglas de Detección

Pregunta: ¿Cuántas reglas/alertas de detección está ejecutando el SIEM?

Opciones:

1. Pocas o ninguna regla; alertas principalmente manuales – Ad-hoc (L0).
2. <50 reglas; alertas genéricas – Basic (L1).
3. 50-200 reglas; cobertura de ataques comunes (brute force, SQL injection) – Moderate (L2).
4. 200-500 reglas; MITRE ATT&CK coverage, con baseline behavior – Comprehensive (L3).
5. >500 reglas + ML-based anomaly detection + threat intelligence correlation – Advanced (L4-L5).

Métrica Auxiliar: Número de alertas/reglas activas: _

Métrica Auxiliar: Número de reglas custom vs pre-built: _

D.7 False Positive Rate

Pregunta: ¿Cuál es la tasa de false positives en alertas?

Opciones:

1. Desconocemos; nunca se mide – Blind (L0).
2. Muy alta (>50%); equipo ignorando alertas – Noisy (L1).
3. Alta (30-50%); impact en fatigue del SOC – Problematic (L2).
4. Aceptable (10-30%); tuning en progreso – Acceptable (L3).
5. Baja (<10%); basada en ML tuning, seasonal patterns, context – Optimized (L4-L5).

Métrica Auxiliar: Tasa de false positive estimada: %

Métrica Auxiliar: Ratio alertas vs incidentes reales: _:1

D.8 Mean Time to Detect (MTTD)

Pregunta: ¿Cuál es el tiempo promedio de detección de una anomalía/ataque?

Opciones:

1. No detectamos; descubrimos por terceros – >Weeks (L0).
2. Detección promedio: 1-4 semanas – Slow (L1).
3. Detección: 3-7 días – Days (L2).
4. Detección: <24 horas para ataques críticos – <1 day (L3).
5. Detección: <1 hora para críticos; <4 horas para altos – Near real-time (L4-L5).

Métrica Auxiliar: MTTD promedio para críticos: _ horas

Métrica Auxiliar: MTTD promedio para altos: _ horas

D.9 Incident Response Workflow Integrado

Pregunta: ¿Existe integración entre SIEM y procesos de incident response?

Opciones:

1. **Alertas SIEM; equipo investiga manualmente** – Manual (L0).
2. **Alerts – ticket en sistema, pero sin workflow automático** – Semi-manual (L1).
3. **Alerts – automated response parcial (ej: isolate endpoint, alert SOC)** – Partial automation (L2).
4. **Workflow automático: alert – investigation – escalation – containment – notification, con SOAR integration** – Orchestrated (L3).
5. **Full automation + human-in-the-loop: automatic containment with approval, learning feedback loops, threat hunting automation** – Advanced (L4-L5).

Métrica Auxiliar: ¿Se utiliza herramienta SOAR integrada con SIEM? (Sí/No). Si sí: _

Métrica Auxiliar: % de alertas con response automático: %

D.10 User and Entity Behavior Analytics (UEBA)

Pregunta: ¿Utiliza UEBA o análisis de comportamiento para detectar anomalías?

Opciones:

1. **No existe UEBA** – No anomaly detection (L0).
2. **Alertas manuales por comportamiento anormal (suspicious patterns)** – Manual (L1).
3. **UEBA básico integrado en SIEM, pero sin ML tuning** – Basic (L2).
4. **UEBA maduro: ML baselines por usuario/entidad, detección lateral movement, account compromise** – Operational (L3).
5. **UEBA avanzado + threat hunting + insider threat detection + risk scoring dinámico** – Advanced (L4-L5).

Métrica Auxiliar: ¿Se tiene solución UEBA separada o integrada? (Separada/Integrada/Ninguna): _

Métrica Auxiliar: % de incidentes detectados vía UEBA: %

D.11 Threat Intelligence Integration

Pregunta: ¿Se correlaciona SIEM con feeds de threat intelligence?

Opciones:

1. **No integración con TI** – Manual lookup (L0).
2. **TI feeds suscritos, pero correlation manual** – Disconnected (L1).
3. **TI feeds integrados en SIEM, alertas cuando IP/hash coincide** – Basic correlation (L2).
4. **TI feeds automático, correlación enriquecida con contexto (asset criticality, location)** – Operational (L3).
5. **Advanced TI integration: dynamic feeds, machine learning correlation, behavioral contextualization** – Sophisticated (L4-L5).

Métrica Auxiliar: Número de TI feeds suscritas: _

Métrica Auxiliar: % de detecciones basadas en TI correlation: %

D.12 SIEM Health & Validation

Pregunta: ¿Se valida regularmente que SIEM está ingiriendo y procesando logs correctamente?

Opciones:

1. **No validamos; asumimos que funciona** – Blind (L0).
2. **Validation ocasional, principalmente por vendor** – Ad-hoc (L1).
3. **Checklists de validación manual trimestral** – Periodic (L2).
4. **Validación automática: agent heartbeat, log ingestion monitoring, gaps reporting** – Automated (L3).
5. **SIEM health dashboard, automated testing, recovery procedures, log gap filling** – Advanced (L4-L5).

Métrica Auxiliar: Disponibilidad de SIEM (% uptime último año): %

Métrica Auxiliar: Porcentaje de datos de logs "perdidos" o no ingiriendo: %

D.13 Reporting y Compliance

Pregunta: ¿Se generan reportes regulares de seguridad a partir de SIEM?

Opciones:

1. **Sin reportes de SIEM** – No reporting (L0).
2. **Reportes ad-hoc cuando se solicita** – Reactive (L1).
3. **Reportes mensuales básicos (top events, alerts)** – Basic (L2).
4. **Reportes mensuales + custom compliance reports (NIS2, GDPR, PCI), con evidencia audit trail** – Operational (L3).
5. **Automated dashboards + executive scorecard + regulatory reporting + trend analysis + anomaly reports** – Advanced (L4-L5).

Métrica Auxiliar: Número de reportes automáticos generados: _

Métrica Auxiliar: Frecuencia de reportes a Dirección (diaria/semanal/mensual/trimestral): _

VI. MÓDULO E: EMPLOYEE TRAINING & AWARENESS (11 PREGUNTAS)

Objetivo de Módulo (Goal - GQM)

Determinar cobertura, efectividad y sostenibilidad de programa de capacitación en ciberseguridad y concienciación.

E.1 Programa de Capacitación Formal

Pregunta: ¿Existe programa formal de capacitación en ciberseguridad para empleados?

Opciones:

1. **No existe programa; la seguridad es "intuitiva"** – Nonexistent (L0).
2. **Capacitación ocasional en eventos de seguridad** – Ad-hoc (L1).
3. **Capacitación anual obligatoria genérica sobre seguridad** – Basic (L2).
4. **Capacitación anual obligatoria + training especializado por rol** – Structured (L3).
5. **Capac. anuales + micro-learning continuo + role-specific paths + competency tracking** – Advanced (L4-L5).

Métrica Auxiliar: % empleados completaron capacitación obligatoria: %

Métrica Auxiliar: Horas de capacitación ciberseguridad/empleado/año: _

E.2 Cobertura de Capacitación

Pregunta: ¿A qué públicos va dirigida la capacitación?

Opciones (Marcar todas):

- Todos los empleados (awareness general) ()
- Roles IT (sysadmin, network, database) ()
- Desarrolladores/engineers ()
- Ejecutivos/board ()
- Recursos Humanos (hiring, employee monitoring) ()
- Finanzas (fraude interno, transacciones sospechosas) ()
- Customer-facing teams (soporte, ventas) ()
- Contratistas/terceros ()
- Nuevos empleados (onboarding security) ()

Métrica Auxiliar: Número de módulos de capacitación disponibles: ____

E.3 Phishing Awareness Test

Pregunta: ¿Se realizan simulacros de phishing regularmente?

Opciones:

1. **Nunca hemos testado phishing; "nuestro equipo es cuidadoso"** – Untested (L0).
2. **Simulacro de phishing ocasional, <1x/año** – Infrequent (L1).
3. **Simulacro trimestral, con feedback básico** – Periodic (L2).
4. **Simulacros mensuales con scoring, ranking departamental, training post-fall** – Regular (L3).
5. **Phishing continuo + AI-powered escenarios + training automático post-click** – Continuous (L4-L5).

Métrica Auxiliar: Frecuencia simulacros phishing: _ **por año**

Métrica Auxiliar: % de empleados que hacen click en phishing: %

Métrica Auxiliar: % que reportan phishing vs ignoran: ____%

E.4 Materiales de Capacitación Disponibles

Pregunta: ¿Qué materiales de capacitación existen?

Opciones (Marcar todas):

- Vídeos de seguridad ()
- Cursos online (e-learning) ()
- Documentación/guías ()
- Talleres presenciales ()
- Micro-learning (tips semanales, podcasts) ()
- Simuladores (sandbox labs) ()

- Gamification (puntos, badges) ()
- Certification paths ()

Métrica Auxiliar: Plataforma de e-learning usada (ej: Knowbe4, Proofpoint, custom): ____

E.5 Efectividad Medida

Pregunta: ¿Se mide la efectividad de la capacitación?

Opciones:

1. **No medimos; asumimos que funciona** – Unmeasured (L0).
2. **Test post-capacitación, pero no se hace seguimiento** – One-off (L1).
3. **Test post-capacitación, scores registrados** – Basic measurement (L2).
4. **Tests + tracking cambio comportamiento (phishing click rate, incidentes reportados)** – Behavioral tracking (L3).
5. **KPI compliance: knowledge + behavior + correlation con incident reduction + ROI** – Advanced (L4-L5).

Métrica Auxiliar: % de empleados que pasaron test post-capacitación: %

Métrica Auxiliar: Cambio en click rate phishing antes vs después capacitación: _% – %

E.6 Capacitación de Nuevos Empleados

Pregunta: ¿Se imparte capacitación de seguridad en onboarding de nuevos empleados?

Opciones:

1. **No existe capacitación de onboarding** – Missing (L0).
2. **Algo de información, pero ad-hoc** – Informal (L1).
3. **Checklist de seguridad en onboarding, sin seguimiento** – Basic (L2).
4. **Curso de onboarding seguridad obligatorio; test de comprensión** – Formal (L3).
5. **Onboarding adaptado por rol + mentoring + 30/60/90d checkpoints** – Structured (L4-L5).

Métrica Auxiliar: % de nuevos empleados que completaron onboarding seguridad: %

Métrica Auxiliar: Tiempo desde hire a completar capacitación: _ días

E.7 Capacitación para Roles Críticos

Pregunta: ¿Existe capacitación especializada para roles de riesgo alto (sysadmins, desarrolladores, CISO, board)?

Opciones:

1. **No existe capacitación especializada** – Homogeneous (L0).
2. **Capacitación general para IT, pero no especializada** – Generic (L1).
3. **Algunos cursos especializados (ej: secure coding, sysadmin hardening)** – Partial (L2).
4. **Capacitación especializada por rol formalizadas, con recertificación** – Operational (L3).
5. **Advanced training paths: secure SDLC, threat modeling, incident management, board cyber literacy** – Advanced (L4-L5).

Métrica Auxiliar: # de cursos especializados ofrecidos: _

Métrica Auxiliar: Horas/año de capacitación especializada por rol: _

E.8 Comunicación Sobre Incidentes y Amenazas

Pregunta: ¿Se comunican regularmente incidentes/amenazas a los empleados?

Opciones:

1. **No comunicamos; "no queremos asustar gente"** – Silent (L0).
2. **Comunicación ocasional tras crisis importante** – Reactive (L1).
3. **Newsletter mensual de seguridad con tips y news** – Regular (L2).
4. **Newsletter + alertas de amenazas emergentes + case studies internos + lecciones aprendidas** – Proactive (L3).
5. **Communication strategy integrada: alertas automáticas + threat dashboards + gaming + culture-building** – Sophisticated (L4-L5).

Métrica Auxiliar: Frecuencia comunicación seguridad a empleados: _ **por mes/año**

Métrica Auxiliar: % de empleados que se subscriben a updates de seguridad: %

E.9 Incidentes Reportados vs Detectados

Pregunta: ¿Qué porcentaje de incidentes de seguridad son descubiertos por empleados vs detectados?

Opciones:

1. **Casi ninguno; descubrimientos accidentales** – <1% (L0).
2. **Pocos empleados reportan; <10%** – Low engagement (L1).
3. **10-20% reportados por empleados** – Moderate engagement (L2).
4. **20-40% reportados; existe canal de reporte claro y sin castigo** – Good engagement (L3).
5. **>40% + bug bounty program + security culture de "buscar hallazgos"** – High engagement (L4-L5).

Métrica Auxiliar: % de incidentes descubiertos por empleados: %

Métrica Auxiliar: Número de reportes seguridad/mes: _

E.10 Divulgación Responsable (Responsible Disclosure)

Pregunta: ¿Existe política/proceso de divulgación responsable de vulnerabilidades?

Opciones:

1. **No existe; empleados no saben dónde reportar** – None (L0).
2. **Existe procedimiento vago** – Informal (L1).
3. **Política documentada, accesible en intranet** – Documented (L2).
4. **Política + contacto claro + confidencialidad garantizada + SLA de respuesta** – Formal (L3).
5. **Policy + bug bounty + Hall of Fame + no-blame culture + rapid response + legal protection** – Advanced (L4-L5).

Métrica Auxiliar: ¿Existe canal formal de reporte (security@company, hotline)? (Sí/No)

Métrica Auxiliar: Reportes de vulnerabilidad/mes: ____

E.11 Evolución de la Conciencia a lo Largo del Tiempo

Pregunta: ¿Se observa mejora en conciencia/comportamiento seguridad a lo largo del tiempo?

Opciones:

1. **Sin mejora; comportamiento igual a hace 5 años** – Stagnant (L0-L1).
2. **Mejora pequeña observable** – Slight improvement (L1-L2).
3. **Mejora clara: click rate down, reportes up, compliance up** – Clear trend (L2-L3).
4. **Mejora sostenida: metrics trending right, cultura cambiada** – Sustained improvement (L3-L4).
5. **Transformación: security es parte del ADN, zero-culture blame, continuous learning** – Transformation (L4-L5).

Métrica Auxiliar: Trend phishing click rate 3 años: % → % → %

Métrica Auxiliar: Trend reportes incidentes 3 años: ____ → ____ → ____ por mes

VII. MÓDULO F: COMPLIANCE & NIS2 READINESS (10 PREGUNTAS)

Objetivo de Módulo (Goal - GQM)

Determinar alineación con normativas (NIS2, GDPR, ENS, ISO 27001) y preparación para auditorías externas.

F.1 Aplicabilidad NIS2

Pregunta: ¿Aplica la Directiva NIS2 a su organización?

Opciones:

1. **No; somos empresa pequeña (<250 empleados) sin servicios esenciales** – Not applicable (L0).
2. **Dudoso; en la frontera, sin claridad legal** – Unclear (L1).
3. **Sí, pero solo algunos aspectos** – Partial applicability (L2).
4. **Sí; somos operador de servicios esenciales o PYMES críticas** – Fully applicable (L3).

Métrica Auxiliar: Sector de actividad: _

Métrica Auxiliar: Número empleados: _

F.2 Alineación NIS2: Medidas Mínimas

Pregunta: ¿Se han implementado las 10 medidas mínimas de NIS2?

Medidas NIS2:

1. Políticas de seguridad y análisis de riesgos
2. Acceso a activos y gestión de identidad
3. Concienciación y capacitación continua
4. Criptografía y cifrado
5. Gestión de incidentes y continuidad negocio

6. Adquisición, desarrollo y mantenimiento de sistemas
7. Gestión de proveedores
8. Gestión de vulnerabilidades
9. Respuesta y recuperación
10. Investigación y prácticas post-incidente

Opciones (escala 0-5 por medida):

Medida	L0	L1	L2	L3	L4	L5
1. Políticas & Risk	()	()	()	()	()	()
2. Acceso & Identity	()	()	()	()	()	()
3. Capacitación	()	()	()	()	()	()
4. Criptografía	()	()	()	()	()	()
5. Incidentes & Continuidad	()	()	()	()	()	()
6. Desarrollo	()	()	()	()	()	()
7. Proveedores	()	()	()	()	()	()
8. Vulnerabilidades	()	()	()	()	()	()
9. Respuesta & Recuperación	()	()	()	()	()	()
10. Post-Incidente	()	()	()	()	()	()

Métrica Auxiliar: Madurez promedio NIS2: ____/5

F.3 Notificación de Incidentes NIS2

Pregunta: ¿Está preparada para notificar a autoridades conforme NIS2 (24h alerta, 72h informe, 30d completo)?

Opciones:

1. **No hemos pensado en notificación; no tenemos estructura** – Unprepared (L0).
2. **Hay algo escrito, pero no probado** – Untested (L1).
3. **Procedimiento de notificación documentado, pero sin validación** – Documented (L2).
4. **Plan formal con simulacro, contactos definidos, SLA documentado** – Tested (L3).
5. **Automatización parcial de notificación (templates, escalation), training periódico del team** – Automated (L4-L5).

Métrica Auxiliar: Tiempo máximo internamente para notificación autoridad: **_ horas**

Métrica Auxiliar: ¿Se ha realizado simulacro de notificación NIS2? (Sí/No). Año: **_**

F.4 Cumplimiento GDPR (Protección de Datos Personales)

Pregunta: ¿Existe programa formal de cumplimiento GDPR?

Opciones:

1. **No; asumimos que GDPR no aplica** – Ignored (L0).
2. **Algo de awareness, pero sin programa formal** – Ad-hoc (L1).
3. **Programa documentado: DPA, privacy policy, consent management** – Documented (L2).
4. **Programa formalizado con auditoría anual, Privacy by Design, Data Subject Rights** – Operational (L3).
5. **Programa avanzado: automated consent management, DPIA automáticas, continuous compliance monitoring** – Automated (L4-L5).

Métrica Auxiliar: ¿Existe Data Protection Officer (DPO)? (Sí/No)

Métrica Auxiliar: Número de DPIAs realizadas: **_**

Métrica Auxiliar: Data Subject Rights requests procesadas en 30 días: **%**

F.5 Cumplimiento ENS (España)

Pregunta: ¿Se aplica el Esquema Nacional de Seguridad (ENS) a su organización?

Opciones:

1. **No aplica; no somos sector público** – Not applicable (L0).
2. **Aplica pero no hay programa formal** – Applicable but ignored (L1).
3. **Algunos controles implementados, pero sin auditoría formal** – Partial (L2).
4. **Cumplimiento documentado, auditoría anual, certificación en proceso** – Formal (L3).
5. **Certificación ENS válida, auditoría periódica, integración en governance** – Certified (L4-L5).

Métrica Auxiliar: ¿Nivel ENS objetivo? (Básico/Medio/Alto): **_**

Métrica Auxiliar: ¿Año de última auditoría ENS? **_**

F.6 Certificaciones ISO 27001/ISO 42001

Pregunta: ¿Tiene certificación ISO 27001 o está en camino?

Opciones:

1. **No; nunca hemos considerado certificación** – None (L0).
2. **En consideración, pero sin plan concreto** – Under consideration (L1).
3. **En proceso de auditoría inicial** – In progress (L2).
4. **Certificada hace 1-3 años, auditoría anual de seguimiento** – Current (L3).
5. **Certificada + ISO 42001 (IA), auditoría sistemática, mejora continua documentada** – Advanced (L4-L5).

Métrica Auxiliar: ¿Año de certificación ISO 27001? _

Métrica Auxiliar: ¿Número de hallazgos en última auditoría de seguimiento? _

F.7 Plan de Continuidad de Negocio (BCP) y Recuperación ante Desastres (DRP)

Pregunta: ¿Existe plan formalizado de continuidad y recuperación?

Opciones:

1. **No existe plan** – Missing (L0).
2. **Existe borrador, pero no formalizado** – Draft (L1).
3. **Plan documentado, pero nunca testado** – Documented, untested (L2).
4. **Plan formal, probado anualmente, con RTO/RPO documentado** – Tested (L3).
5. **Plan integrado, probado 2x/año, automatización parcial, conocimiento distribuido** – Advanced (L4-L5).

Métrica Auxiliar: RTO (Recovery Time Objective) objetivo: _ horas

Métrica Auxiliar: RPO (Recovery Point Objective) objetivo: _ horas

Métrica Auxiliar: % de sistemas cubiertos por BCP/DRP: __%

F.8 Auditoría Externa

Pregunta: ¿Se realiza auditoría externa de ciberseguridad regularmente?

Opciones:

1. **Nunca; solo auditoría interna** – None (L0).
2. **Auditoría externa ocasional (cada 3-5 años)** – Infrequent (L1).
3. **Auditoría externa bianual** – Periodic (L2).
4. **Auditoría externa anual con seguimiento de hallazgos** – Regular (L3).
5. **Auditorías múltiples: ISO, SOC 2, penetration, compliance, con continuous assurance** – Advanced (L4-L5).

Métrica Auxiliar: ¿Año de última auditoría externa? _

Métrica Auxiliar: Hallazgos abiertos >6 meses: _

F.9 Seguimiento de Regulaciones en Evolución

Pregunta: ¿Se monitorean cambios regulatorios (AI Act, CRA, futuras directivas)?

Opciones:

1. **No; nos enteramos cuando afecta** – Reactive (L0).
2. **Lectura ocasional de noticias de compliance** – Passive (L1).
3. **Subscripción a alertas de compliance, revisión trimestral** – Proactive (L2).
4. **Equipo dedicado a compliance monitoring, impact assessments de nuevas regs** – Structured (L3).
5. **Real-time regulatory intelligence + impact analysis + proactive advocacy + scenario planning** – Sophisticated (L4-L5).

Métrica Auxiliar: Regulaciones monitoreadas: ____

Métrica Auxiliar: Documento de Impact Assessment de NIS2: (Sí/No)

F.10 Tabletop Exercises & Crisis Simulation

Pregunta: ¿Se realizan ejercicios de simulación de crisis regularmente?

Opciones:

1. **No; nunca hemos simulado** – Untested (L0).
2. **Simulación ad-hoc tras incidente importante** – Reactive (L1).
3. **Tabletop anual, escenario genérico** – Periodic (L2).
4. **Tabletop anual + red team exercise bianual, escenarios específicos a org** – Regular (L3).
5. **Simulaciones continuas: quarterly tabletop, monthly incident drills, AI-generated scenarios** – Advanced (L4-L5).

Métrica Auxiliar: ¿Año del último tabletop exercise? _

Métrica Auxiliar: Duración típica: _ horas

Métrica Auxiliar: Participantes: Ejecutivos() CISO() Ops() Legal() PR() CEO()

VIII. INSTRUCCIONES DE RESPUESTA Y PUNTUACIÓN

8.1 Cómo Completar la Encuesta

6.
Responsable: Ser respondida por CISO, Director Seguridad o equivalente; coordinando entrada con equipos (ops, dev, infra).
7.
Tiempo estimado: 2-3 horas si se prepara con evidencia.
8.
Evidencia: Para cada respuesta L3+, documento una línea de evidencia (política, reporte, screenshot, etc.).
9.
Honestidad: No es evaluación punitiva; responder con honestidad acelera mejora.
10.
Métricas cuantitativas: Siempre usar números; si no se tiene, estimar conservadoramente.

Responsable: Ser respondida por CISO, Director Seguridad o equivalente; coordinando entrada con equipos (ops, dev, infra).

Tiempo estimado: 2-3 horas si se prepara con evidencia.

Evidencia: Para cada respuesta L3+, documento una línea de evidencia (política, reporte, screenshot, etc.).

Honestidad: No es evaluación punitiva; responder con honestidad acelera mejora.

Métricas cuantitativas: Siempre usar números; si no se tiene, estimar conservadoramente.

8.2 Puntuación y Scoring

Escala de Madurez Agregada:

- L0-L1 (Ad-hoc): 0-30% → "Iniciando" → Alto riesgo
- L2 (Establecido): 31-50% → "Básico" → Riesgo moderado
- L3 (Operativo): 51-75% → "Maduro" → Riesgo controlado (TARGET 2026 NIS2)
- L4 (Gestionado): 76-90% → "Avanzado" → Riesgo bajo
- L5 (Optimizado): 91-100% → "Líder" → Riesgo optimizado

Cálculo:

11. Convertir cada respuesta L1-L5 a puntuación 0-100 (L1=20, L2=40, L3=60, L4=80, L5=100).
12. Promediar dentro de cada módulo.
13. Promediar módulos para score global.

8.3 Ejemplo de Cálculo

Módulo	# Preguntas	Score Promedio	Ponderación	Contribución
A (Governance)	12	65	20%	13.0
B (Risk & Vuln)	14	52	20%	10.4
C (Pentesting)	10	71	15%	10.7
D (SIEM)	13	58	20%	11.6
E (Training)	11	48	15%	7.2
F (Compliance)	10	62	10%	6.2
TOTAL	70		100%	59.1

Interpretación: Score 59.1 – L3 bajo (Operativo, sobre baseline, pero brecha en Risk/Training).
Requiere mejora en B y E para alcanzar L3 completo (60+).

IX. CIERRE: LA INVITACIÓN A LA TRANSFORMACIÓN

Esta encuesta no es un punto final, sino un punto de partida. Cada respuesta que marca L1 o L2 no es un fracaso; es un mapa. Cada brecha identificada es una oportunidad.

La ciberseguridad madura no surge de herramientas sofisticadas ni inversiones heroicas. Surge de **constancia, medición, aprendizaje y cultura**. Esta encuesta, respondida con rigor y sin autoengaño, es el primer paso de ese camino.

Adelante. La seguridad de su organización depende de esta honestidad inicial.

FIN DEL MODELO DE ENCUESTA